

AEGIS GUARD

Behavioral Twin Prompt Injection Firewall

Agentic Cybersecurity · Solo build · Python

Team: Abhishek — Product · Architecture · Full-stack implementation

Live · aegis-prompt-injection-firewall.vercel.app

GitHub · github.com/krabhi75/aegis-prompt-injection-firewall

Problem statement

Agents touch untrusted content

PDF, email, HTML, OCR, and APIs now feed tool-using agents. Attackers hide instructions inside those documents.

Indirect prompt injection

A single poisoned attachment can trigger `get_secret`, `send_email`, or shell tools — without the user noticing.

Classifiers are not enough

Keyword / LLM jailbreak detectors ask: “Does this look bad?” Attackers evade that every day.

Enterprises are shipping copilots and agents into production workflows.

Without a runtime control plane, every document becomes an attack surface.

Proposed solution — runtime twin, not classification

Prompt injection is a runtime security problem:

Does untrusted content change what tools the agent would call?

Aegis Guard runs a behavioral twin:

- Trusted plan — instructions with untrusted content stripped
- Raw plan — instructions as attackers hope the agent will see them
- If plans diverge on high-risk tools → BLOCK or QUARANTINE

Everyone else ships a classifier. We ship a twin.

Aegis Guard control plane

01 Ingest

Normalize PDF, HTML, email, OCR, API

02 Decode

Unwrap base64 / hex / rot13 / homoglyphs

03 Provenance

Tag trusted vs untrusted spans

04 Static

Detect 9 attack families

05 Twin

Dual tool-plan comparison

06 Risk + Gate

ALLOW · QUARANTINE · BLOCK

Architecture

Ingest → Decode → Provenance → Static → Behavioral Twin → Risk → Gate

Protected Agent (capability tokens) · Analyst Quarantine (HITL)

- Capability tokens fail-closed on secrets, shell, external email
- SQLite audit trail + incident JSON export
- Session risk memory for multi-step jailbreaks
- Optional OpenAI-compatible LLM planner (offline twin by default)
- Repo: github.com/krabhi75/aegis-prompt-injection-firewall

AI models & technologies

Agentic AI in the product

- Dual planner (trusted vs raw tool trajectories)
- Deterministic offline planner by default
- Optional OpenAI-compatible / Ollama enrichment
- Protected agent executes only on ALLOW
- Session memory for multi-step jailbreaks

Engineering stack

- Python 3.11 · FastAPI · Pydantic v2
- Streamlit analyst console (local)
- Vercel Executive Console (production)
- pypdf · BeautifulSoup · Pillow (+ OCR)
- SQLite audit · pytest · 55-sample corpus

Product demo — proof points

Benign product PDF	ALLOW	Trusted summarize path
Indirect injection in PDF	BLOCK	Twin drift: get_secret + send_email
Encoded HTML jailbreak	BLOCK	Decode layer + override
Multi-step roleplay → tools	QUARANTINE / BLOCK	Session risk escalation
Human analyst queue	HITL	Approve / deny with audit note

Business impact

Risk reduction

Block secret theft and tool abuse before execution — agents stay useful on benign documents.

Audit & governance

Incident JSON, decision trails, OWASP LLM Top 10 & NIST AI RMF mapped controls.

Human oversight

Quarantine band keeps analysts in the loop — fail-closed on high risk.

Scalability

Designed as a side-car control plane in front of any tool-using agent:

- Stateless scan API — horizontal scale behind a load balancer
- Offline twin by default — predictable latency without LLM round-trips
- Optional LLM planner only where enrichment adds value
- SQLite today → Postgres / object storage for multi-tenant audit
- Capability tokens enforce least privilege per tenant / agent role
- Corpus + pytest gate regressions as detectors grow

Same pattern works for email triage, ticket agents, and document copilots.

Future roadmap

Near term

Deeper OCR / Word paths · richer policy packs
· SIEM / webhook exporters · stronger
multi-tenant audit.

Mid term

Native SDK embeds · streaming scan for long
docs · adaptive thresholds per agent role ·
red-team corpus growth.

North star

Default runtime firewall for enterprise agents —
twin + provenance + caps as industry pattern.

Everyone else ships a classifier.

We ship a twin.

If the document tries to make your agent steal secrets,
the plans diverge — and Aegis blocks before a single tool runs.

Live · aegis-prompt-injection-firewall.vercel.app · Thank you